

Macaroons: Cookies with Contextual Caveats for Decentralized Authorization in the Cloud

Arnar Birgisson
Chalmers University of Technology
arnarbi@gmail.com

Joe Gibbs Politz
Brown University
joe@cs.brown.edu

Úlfar Erlingsson, Ankur Taly,
Michael Vrabie, and Mark Lentczner
Google Inc
{ulfar,ataly,mvrabie,mzero}@google.com

Abstract—Controlled sharing is fundamental to distributed systems; yet, on the Web, and in the Cloud, sharing is still based on rudimentary mechanisms. More flexible, decentralized cryptographic authorization credentials have not been adopted, largely because their mechanisms have not been incrementally deployable, simple enough, or efficient enough to implement across the relevant systems and devices.

This paper introduces *macaroons*: flexible authorization credentials for Cloud services that support *decentralized delegation* between principals. Macaroons are based on a construction that uses nested, chained MACs (e.g., HMACs [43]) in a manner that is highly efficient, easy to deploy, and widely applicable.

Although macaroons are bearer credentials, like Web cookies, macaroons embed *caveats* that *attenuate* and *contextually confine* when, where, by who, and for what purpose a target service should authorize requests. This paper describes macaroons and motivates their design, compares them to other credential systems, such as cookies and SPKI/SDSI [14], evaluates and measures a prototype implementation, and discusses practical security and application considerations. In particular, it is considered how macaroons can enable more fine-grained authorization in the Cloud, e.g., by strengthening mechanisms like OAuth2 [17], and a formalization of macaroons is given in authorization logic.

I. INTRODUCTION

Macaroons are authorization credentials that provide flexible support for controlled sharing in decentralized, distributed systems. Macaroons are widely applicable since they are a form of bearer credentials—much like commonly-used cookies on the Web—and have an efficient construction based on keyed cryptographic message digests [43].

Macaroons are designed for the Web, mobile devices, and the related distributed systems collectively known as the *Cloud*. Such modern software is often constructed as a decentralized graph of collaborative, loosely-coupled services. Those services comprise different protection domains, communication channels, execution environments, and implementations—with each service reflecting the characteristics and interests of the different underlying stakeholders. Thus, security and access

control are of critical concern, especially as the Cloud is commonly used for sharing private, sensitive end-user data, e.g., through email or social networking applications.

Unfortunately, controlled sharing in the Cloud is founded on basic, rudimentary authorization mechanisms, such as HTTP cookies that carry pure bearer tokens [21, 54]. Thus, today, it is practically impossible for the owner of a private, sensitive image stored at one Cloud service to email a URL link to that image, safely—given the many opportunities for impersonation and eavesdropping—such that the image can be seen only by logged-in members of a group of users that the owner maintains at another, unrelated Cloud service. Currently, this use case is possible only if the image, access group, and users are all at a single service, or if two Cloud services keep special, pairwise ties using custom, proprietary mechanisms (e.g., as done by Dropbox and Facebook [55]).

Of course, the ubiquitous use of bearer tokens is due to advantages—such as simplicity and ease of adoption—that cannot be overlooked. For example, bearer tokens can easily authorize access for unregistered users (e.g., to the shopping cart of a first-time visitor to a Cloud service) or from unnamed, transient contexts (e.g., from a pop-up window shown during private, incognito Web browsing). Such dynamic and short-lived principals arise naturally in distributed systems, like the Cloud and the “Grid” [47]. In comparison, most authorization mechanisms based on public-key certificates are not directly suited to the Cloud, since they are based on more expensive primitives that can be difficult to deploy, and define long-lived, linkable identities, which may impact end-user privacy [21].

Even so, the inflexibility of current Cloud authorization is quite unsatisfactory. Most users will have first-hand experience of the resulting frustrations—for example, because they have clicked on a shared URL, only to be redirected to a page requesting account creation or sharing of their existing online identity. Similarly, many users will have uncomfortably surrendered their passwords to use some Cloud service functionality, such as to populate an address book (e.g., on LinkedIn.com) or to aggregate their financial data (e.g., on mint.com).

Macaroons aim to combine the best aspects of using bearer tokens and using flexible, public-key certificates for authorization, by providing (i) the wide applicability, ease-of-use, and privacy benefits of bearer credentials based on fast cryptographic primitives, (ii) the expressiveness of truly decentralized credentials based on authorization logic, like SPKI/SDSI [14], and (iii) general, precise restrictions on how, where, and when credentials may be used.